

CLOUD SERVICE PROVIDER MANAGEMENT POLICY

Based on SANS/CRF Cybersecurity Policy Template, February 2026
Application Security Category

Version	Effective Date	Document Owner	Status
1.0	March 28, 2026	Noe Valencia	Active

Do not distribute externally.

1. Purpose

This Cloud Service Provider Management Policy establishes a comprehensive and systematic framework for the selection, engagement, and continuous oversight of cloud services within our organization. Cloud service providers and the SaaS, PaaS, and IaaS platforms they deliver have become foundational to modern IT operations. Their security, availability, and compliance posture directly affects every system, user, and data asset that depends on them.

This policy delineates clear criteria and protocols for evaluating potential cloud service providers, ensuring they meet our security, privacy, and operational performance standards. By laying out structured due diligence procedures, configuration benchmarks, vulnerability management requirements, and data loss prevention controls, this policy mitigates the risks associated with cloud computing including data breaches, service disruptions, misconfigurations, and compliance failures.

2. Scope

This policy applies to all personnel within our organization, including full-time employees, part-time staff, consultants, and external business partners who select, procure, configure, manage, or use cloud computing resources on behalf of the organization. It encompasses all cloud service models in use across our infrastructure:

- Infrastructure-as-a-Service (IaaS) including AWS, Microsoft Azure, and Google Cloud Platform
- Platform-as-a-Service (PaaS) including application hosting, database, and container platforms
- Software-as-a-Service (SaaS) including all third-party cloud-hosted business applications
- Any hybrid or multi-cloud arrangement combining the above

Compliance with this policy is mandatory for all in-scope individuals and applicable to all cloud engagements regardless of contract size or duration. Exemptions or deviations require formal review and approval by the IT Security Manager per Section 12.

3. Principle Statement

Cloud service provider relationships are governed under a shared responsibility model. Our organization accepts full accountability for the security controls it implements on top of cloud platforms, and requires cloud service providers to demonstrate adequate security, compliance, and operational standards before engagement and on an ongoing basis thereafter.

All cloud governance decisions are guided by the principle of least privilege, Zero Trust, and continuous verification. No cloud service is trusted by default. Every provider must be inventoried, benchmarked, scanned, and monitored. The CIA Triad of Confidentiality, Integrity, and Availability governs all cloud security decisions. Sensitive organizational data processed, stored, or transmitted through any cloud platform is subject to the full protections of this policy.

4. Senior Management Commitment

Senior management is fully committed to the governance, oversight, and security of all cloud service engagements. We recognize that cloud misconfigurations and unsanctioned cloud usage represent among the highest-risk exposures facing organizations today, and we commit to the resources, tooling, and governance processes required to manage this risk effectively.

This policy will be reviewed no less than annually and updated in response to material changes in the organization's cloud service portfolio, applicable regulatory requirements, or the threat environment.

Signed: _____ Date: _____
Chief Information Security Officer / Senior IT Leadership

5. How Similar Organizations Handle Cloud Service Provider Management

Research into peer organizations and industry frameworks reveals consistent governance patterns that inform the controls in this policy.

5.1 University Sector, Cloud Governance at Scale

Large universities managing hundreds of SaaS platforms and multi-cloud IaaS environments have developed tiered approval frameworks for cloud service procurement. A common model requires that any cloud service handling regulated data (FERPA, HIPAA, PCI) undergo a formal security review before procurement approval is granted. Shadow IT discovery tools are deployed to identify unsanctioned SaaS usage, and a centralized cloud service registry is maintained by IT. Services are categorized by data classification level, with higher-risk platforms subject to more frequent security assessments. This mirrors the CSP-01 through CSP-04 inventory requirements in this policy.

5.2 Financial Services Sector, DORA and Vendor Risk Management

Under the EU Digital Operational Resilience Act (DORA), which took effect January 2025, financial services organizations are required to maintain a register of all ICT third-party service providers, conduct regular risk assessments of critical cloud providers, ensure contractual rights to audit and exit, and test operational resilience including cloud provider failure scenarios. These requirements directly parallel CSP-01 through CSP-08 and have set a new benchmark for cloud vendor governance in regulated industries. Organizations subject to PCI DSS similarly maintain continuous configuration scanning of cloud environments hosting cardholder data, aligning with CSP-08.

5.3 Federal Government, FedRAMP Authorization Framework

The U.S. Federal Risk and Authorization Management Program (FedRAMP) establishes a standardized security assessment and authorization process for cloud products and services used by federal agencies. FedRAMP-authorized providers have undergone independent third-party assessment against NIST SP 800-53 controls. Federal agencies are required to use only FedRAMP-authorized services for government data, maintain inventories of authorized cloud services, and monitor cloud environments continuously. While FedRAMP applies specifically to federal agencies, its framework has become a de facto benchmark for cloud security expectations in commercial enterprises, particularly for vendors seeking to serve government or regulated-industry clients.

6. Current Industry Trends (2026)

This policy is designed to address the current and near-term cloud security landscape. The following trends directly shaped the safeguards defined in Section 7.

6.1 Misconfiguration Remains the Top Cloud Risk

Gartner projects that through 2025, 99% of cloud security failures are the customer's fault, primarily due to misconfiguration. Public cloud security incidents averaged \$5.17 million per data breach in 2024, up 13.1% year over year. The UnitedHealthcare breach in 2025, which exposed 192.7 million patient records, was partially attributed to identity drift and misconfigured cloud permissions. CSP-05, CSP-06, CSP-07, and CSP-08 directly address this by requiring maintained configuration benchmarks and continuous vulnerability scanning across all cloud platforms.

6.2 Multi-Cloud and Hybrid Cloud Complexity

Flexera's 2025 State of the Cloud report found that 70% of organizations use hybrid cloud strategies with at least one public and one private cloud. The U.S. cloud market is expected to exceed \$1 trillion in 2026. This multi-cloud reality means organizations must track authorized services and accounts not just within one provider but across AWS, Azure, Google Cloud, and dozens of SaaS platforms simultaneously. CSP-01 through CSP-04 provide the inventory foundation required to maintain visibility across this complex landscape.

6.3 Shadow IT and Unsanctioned SaaS Proliferation

The rapid adoption of cloud-based productivity and AI tools has made shadow IT a critical risk. Employees routinely onboard SaaS tools without IT approval, creating data governance gaps and unmonitored attack surfaces. Organizations saw nearly five times as many daily cloud-based alerts at the end of 2024 compared to the start of the year. CSP-03 (SaaS inventory) and CSP-09 (DLP monitoring) are designed specifically to detect and control unauthorized data flows through unsanctioned cloud services.

6.4 Data Loss Prevention in the Cloud Era

Traditional DLP tools were designed for on-premises environments. Modern cloud-native DLP solutions now integrate directly with SaaS platforms such as Microsoft 365, Google Workspace, Salesforce, and Slack to monitor data movement, detect policy violations, and alert on potential exfiltration in real time. CSP-09 mandates a cloud-aware DLP system as a core control, reflecting the industry consensus that data protection cannot stop at the corporate network perimeter.

6.5 Centralized Log Aggregation and CSPM

Cloud Security Posture Management (CSPM) platforms have become standard practice for organizations with significant cloud footprints. These tools continuously assess cloud configurations against security benchmarks, aggregate logs from multiple cloud providers into a centralized SIEM, and alert on policy drift in real time. CSP-10 and CSP-11 mandate that cloud logs are enabled and aggregated centrally, enabling the threat detection and incident response capabilities that modern cloud environments require.

6.6 Sovereign Cloud and Regulatory Pressure

In 2026, organizations in regulated industries are increasingly moving toward sovereign cloud deployments where data residency, privacy, and regulatory compliance are built into the infrastructure. DORA (January 2025), updated state privacy laws including Minnesota's Consumer Data Privacy Act (July 2025), and ongoing GDPR enforcement are driving

organizations to ensure their cloud providers can demonstrate compliance with applicable data protection requirements. This regulatory environment reinforces the due diligence and benchmarking requirements in CSP-05 through CSP-07.

7. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; maintains cloud service registry; approves new CSP engagements; conducts annual review; manages exceptions
Cloud/Systems Administrator	Implements configuration benchmarks; manages CSP accounts; operates vulnerability scanning and DLP tools; maintains log aggregation
IT Manager	Reviews and approves CSP procurement requests; ensures budget for security tooling; escalates risks to leadership
Procurement/Legal	Ensures cloud service contracts include required security, audit, and data protection provisions before execution
Security Analyst	Monitors DLP alerts and cloud vulnerability scan results; reviews aggregated logs; escalates anomalies
All Staff and Contractors	Must use only authorized cloud services; must not connect organizational data to unsanctioned platforms; must report unsanctioned usage

8. Policy Safeguards

The following safeguards are derived from the SANS/CRF Cloud Service Provider Management Policy template (February 2026) and expanded with technical rationale grounded in CIS Controls v8, NIST SP 800-53, and current industry practice. All safeguards are mandatory unless a formal exception has been granted per Section 12.

8.1 Inventory and Authorization Management

Control	Safeguard	Technical Rationale and Industry Alignment
CSP-01	Maintain a current, complete inventory of all authorized Cloud Service Providers (CSPs), including provider name, service tier, data classification, contractual status, and assigned owner.	You cannot govern what you cannot see. CIS Control 1 mandates asset inventory as the foundation of all security. The University sector, FedRAMP, and DORA all require cloud service registries. This inventory is the authoritative source for all downstream controls.
CSP-02	Maintain an inventory of each specific service authorized for use within each approved CSP, including AWS services, Azure resources, GCP products, and equivalent offerings.	CSPs offer hundreds of individual services, each with its own security configuration and risk profile. Maintaining service-level inventory ensures unused or unauthorized services within an approved provider are identified and either secured or disabled.

Control	Safeguard	Technical Rationale and Industry Alignment
CSP-03	Maintain a separate, complete inventory of all authorized SaaS providers, including application name, business owner, data types processed, and review date.	SaaS proliferation is a leading driver of shadow IT and data governance gaps. A dedicated SaaS inventory enables DLP policy enforcement (CSP-09), access reviews (CSP-04), and regulatory compliance reporting.
CSP-04	Maintain an inventory of all accounts authorized for use in each approved CSP or SaaS provider, including account type, owner, and access level. Remove or disable accounts that are no longer needed.	Identity drift, where permissions expand beyond intended scope over time, was a root cause in multiple major 2025 cloud breaches. Account inventory enables regular access reviews and immediate deprovisioning when staff depart or roles change.

8.2 Configuration Benchmarks

Control	Safeguard	Technical Rationale and Industry Alignment
CSP-05	Maintain documented cybersecurity configuration benchmarks for each authorized CSP, aligned to the CIS Benchmarks for AWS, Azure, GCP, or equivalent provider-specific standards.	CIS Benchmarks provide consensus-based hardening guidance for major cloud providers. Gartner's finding that 99% of cloud failures are customer-caused makes documented benchmarks essential. These baselines are the foundation against which CSP-08 vulnerability scans are measured.
CSP-06	Maintain documented configuration benchmarks for each individual service authorized within each CSP, covering compute, storage, networking, identity, and logging configurations.	Service-level misconfiguration is the most common cloud security failure mode. An S3 bucket misconfigured as public, an overly permissive IAM role, or an unsecured Kubernetes cluster each represent critical risks. Service-level benchmarks close these gaps that provider-level benchmarks alone cannot address.
CSP-07	Maintain documented cybersecurity configuration benchmarks for each authorized SaaS provider, including authentication requirements, data sharing controls, API access permissions, and retention settings.	SaaS applications handle organizational data under configurations that must be explicitly hardened. Default SaaS configurations frequently allow overly broad data sharing, weak authentication, and excessive third-party integrations. Benchmarks ensure security teams can detect and remediate drift from secure baseline settings.

8.3 Vulnerability Management, DLP, and Logging

Control	Safeguard	Technical Rationale and Industry Alignment
CSP-08	Maintain a cloud configuration vulnerability management system (CSPM tool) to regularly scan all authorized CSPs and SaaS providers for misconfigurations,	CSPM platforms such as Wiz, Prisma Cloud, and Microsoft Defender for Cloud continuously assess cloud environments against security benchmarks and alert on

Control	Safeguard	Technical Rationale and Industry Alignment
	policy violations, and cybersecurity vulnerabilities. Scans must run at minimum weekly.	configuration drift. This control aligns with CIS Control 4 (Secure Configuration) and NIST SI-2.
CSP-09	Maintain a cloud-aware Data Loss Prevention (DLP) system integrated with all authorized CSPs and SaaS providers to log and alert on potential data loss events, unauthorized data transfers, and policy violations in real time.	Cloud-native DLP tools detect when sensitive data is downloaded to personal devices, shared externally, or transferred to unsanctioned services. As SaaS proliferation increases data exposure risk, DLP is the primary control for enforcing data governance policies across cloud platforms. Aligns with NIST SC-28 and CIS Control 3.
CSP-10	Ensure that appropriate audit and security logs are enabled on all authorized cloud platforms, including authentication events, configuration changes, data access, and administrative actions.	Disabled logging is one of the most common post-breach findings in cloud incidents. Without logs enabled at the platform level, incident response is blind. This control ensures the telemetry required for threat detection, forensic investigation, and compliance reporting is captured at the source.
CSP-11	Ensure that all cloud logs are aggregated into the organization's centralized log management system or SIEM within 24 hours of generation. Retain cloud logs for a minimum of 90 days online and 1 year in archive.	Centralized log aggregation is required for effective threat detection, correlation across platforms, and regulatory compliance. Aggregating cloud logs into a SIEM enables AI-driven anomaly detection and provides the unified audit trail required by NIST AU-9, CIS Control 8, DORA, and PCI DSS.

9. Legal and Regulatory Obligations

This policy supports compliance with the following legal, regulatory, and contractual frameworks:

Framework / Standard	Relevance to This Policy
NIST CSF 2.0	Govern (GV), Protect (PR), and Detect (DE) functions covering cloud asset management, configuration control, and monitoring
NIST SP 800-53 Rev 5	CA (Assessment and Authorization), CM (Configuration Management), SI (System and Information Integrity), AU (Audit and Accountability)
CIS Controls v8	Controls 1 (Asset Inventory), 3 (Data Protection), 4 (Secure Configuration), 6 (Access Control Management), 8 (Audit Log Management)
ISO/IEC 27001:2022	Annex A: Supplier relationships (A.5.19), Cloud services (A.5.23), Information security in supplier agreements (A.5.20)
FedRAMP	Federal cloud authorization framework requiring CSP inventory, configuration assessment, and continuous monitoring

Framework / Standard	Relevance to This Policy
DORA (Digital Operational Resilience Act)	Mandates ICT third-party risk management, CSP registers, and operational resilience testing for financial sector organizations (effective January 2025)
PCI DSS v4.0	Requires secure configuration and continuous monitoring of cloud environments hosting cardholder data
Applicable State and Federal Privacy Laws	Including Minnesota Consumer Data Privacy Act (July 2025), COPPA amendments (June 2025), GDPR, and CCPA for any personal data processed in cloud environments

10. Training and Awareness

All personnel with responsibilities under this policy must receive training appropriate to their role:

- Cloud/Systems Administrators: Annual training on secure cloud configuration standards, CSPM tool operation, DLP system management, and cloud incident response procedures.
- Procurement and Legal Staff: Training on cloud vendor security assessment requirements, contractual security provisions, and data processing agreement obligations.
- All Staff and Contractors: General security awareness training covering the prohibition on using unsanctioned cloud services for organizational data, the risks of shadow IT, and the procedure for requesting approval of new cloud tools.

Training completion records are maintained by the IT Security Team and retained for a minimum of three years.

11. Compliance Measurement

Compliance with this policy is assessed through the following scheduled activities:

Activity	Controls Assessed	Frequency
CSP and SaaS inventory review	CSP-01, CSP-02, CSP-03, CSP-04	Quarterly
Configuration benchmark review	CSP-05, CSP-06, CSP-07	Semi-annual
CSPM vulnerability scan review	CSP-08	Weekly (automated) + Monthly report
DLP alert review	CSP-09	Continuous (automated) + Monthly report
Cloud log enablement audit	CSP-10	Quarterly
Log aggregation verification	CSP-11	Monthly

Activity	Controls Assessed	Frequency
Full policy compliance assessment	All CSP controls	Annual

Results are documented, reported to the IT Security Manager, and retained for three years minimum. Material findings are escalated to senior IT leadership within 5 business days.

12. Exception Management

Operational or business circumstances may occasionally require temporary use of an unapproved cloud service or deviation from a specific safeguard. All exceptions must follow this process:

- The requesting party submits a written exception request to the IT Security Manager documenting the specific control or CSP affected, the business justification, a risk assessment, proposed compensating controls, and the requested duration (maximum 90 days).
- Exceptions require written approval from the IT Security Manager. Exceptions involving personal data or regulated data processed in an unapproved cloud service also require Legal review.
- All approved exceptions are logged in the exception register with the justification, compensating controls, approving authority, and expiration date.
- The exception register is reviewed monthly. Expired exceptions not formally renewed are treated as policy violations.

13. Policy Sanctions

Non-compliance with this policy will result in disciplinary action consistent with the organization's human resources policies. Sanctions are applied consistently and proportionally:

Severity	Consequence
Minor / Unintentional	Mandatory refresher training; written notice placed in personnel file; increased compliance monitoring for 90 days
Moderate / Negligent	Formal written warning; temporary suspension of cloud service access privileges; mandatory security review with IT Security Manager
Severe / Willful Violation	Immediate suspension of all cloud access; HR investigation; potential termination of employment or contract
Criminal / Illegal Activity	All above consequences plus referral to law enforcement; legal action under applicable federal and state statutes

14. Continual Improvement

This policy is reviewed at minimum annually. Earlier review is triggered by any of the following:

- Addition or removal of a significant cloud service provider or SaaS platform
- A cloud-related security incident, data breach, or DLP event

- Material changes to applicable regulatory requirements or CIS Benchmark updates
- Findings from internal compliance assessments, third-party audits, or penetration testing
- Significant changes in the organization's cloud strategy such as migration to a new provider or multi-cloud adoption

The IT Security Manager coordinates annual reviews, incorporates lessons learned from incidents, benchmarks against peer organizations and regulatory frameworks, and ensures the policy reflects the current cloud threat environment. All revisions are documented in the version history and communicated to all in-scope personnel within 10 business days of approval.

15. Sources and References

Source	URL
SANS/CRF Cloud Service Provider Management Policy Template (Feb 2026)	https://www.sans.org/information-security-policy/cloud-service-provider-management-policy
CIS Controls v8	https://www.cisecurity.org/controls/v8
CIS Benchmarks for AWS, Azure, GCP (2026)	https://www.cisecurity.org/cis-benchmarks
NIST SP 800-53 Rev 5	https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final
NIST Cybersecurity Framework (CSF) 2.0	https://www.nist.gov/cyberframework
ISO/IEC 27001:2022	https://www.iso.org/standard/82875.html
FedRAMP Authorization Framework	https://www.fedramp.gov
Flexera 2025 State of the Cloud Report	https://www.flexera.com/blog/finops/the-latest-cloud-computing-trends-flexera-2025-state-of-the-cloud-report/
TechTarget: 5 Cloud Trends to Watch in 2026	https://www.techtarget.com/searchCloudComputing/opinion/5-cloud-trends-to-watch-for-in-2026
CloudQuery: Cloud Governance Framework 2026	https://www.cloudquery.io/learning-center/four-steps-to-designing-your-cloud-governance-framework
White and Case: Privacy and Cybersecurity 2025 to 2026	https://www.whitecase.com/insight-alert/privacy-and-cybersecurity-2025-2026-insights-challenges-and-trends-ahead
Kentik: Cloud Security Policy Management	https://www.kentik.com/kentipedia/cloud-security-policy-management/
ONEXT Digital: 2026 Trends in Cloud Managed Services	https://onextdigital.com/public-cloud-managed-services-2026-trends/